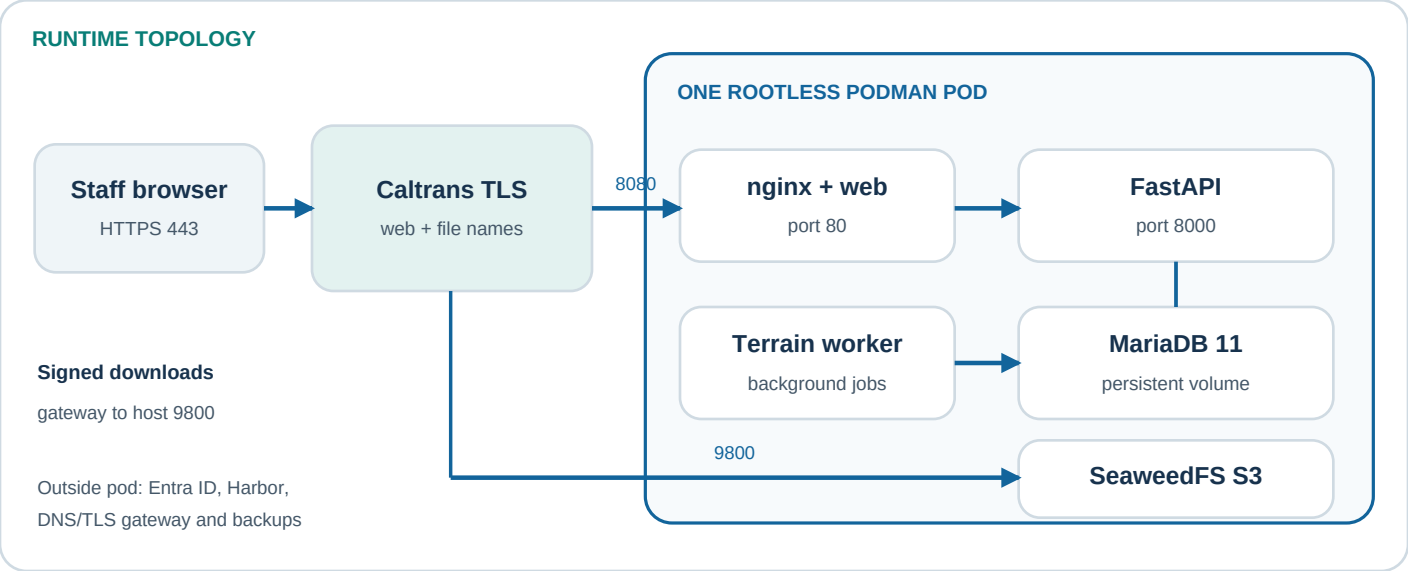
CALTRANS IT DISCUSSION / ARCHITECTURE

ERIS deployment briefing

One Linux Podman pod, five containers, two persistent data volumes. Staff sign in only through Caltrans Entra single sign-on, with no ERIS passwords. Caltrans owns the platform and security boundary; the ERIS team supplies application code and deployment artifacts.

First decision: does Caltrans mean a Podman pod on a Linux VM, or a Kubernetes/OpenShift Pod? These artifacts implement Podman. Confirm that MariaDB and object storage may run in the same pod.



Evidence uploads follow browser to FastAPI to private S3. The separate file hostname serves short-lived signed downloads through the TLS gateway.

Stack at a glance

Inside the pod	Outside the pod / Caltrans-owned
nginx + React web; Python/FastAPI API; terrain worker	DNS/TLS gateway, firewall and public HTTPS names
MariaDB 11 metadata + SeaweedFS 4.50 S3 objects	Entra ID, Jenkins, Harbor, backup and monitoring
Host publishes only 8080 (web/API) and 9800 (S3)	Gateway exposes HTTPS 443; internal DB/API ports stay private

Current Campos Labs Proxmox pod is a packaging rehearsal, not Caltrans acceptance: it uses local image tags, Cloudflare/Caddy and password sign-in. Harbor, Caltrans Entra, security policy and off-host recovery still need joint tests.

DATA / IDENTITY / SECURITY

What is implemented, and what needs approval

Area	ERIS today	Caltrans decision
Data	MariaDB holds accounts, roles, incidents, assessments, workflows and metadata. SeaweedFS holds photos, attachments, PDFs and terrain packages.	Classification, retention, legal hold, and whether to import any existing data.
Recovery	Two persistent named volumes; the database and object store must be restored together with runtime secrets.	Encrypted off-host backup, RPO/RTO, restore drill and single-host failure plan.
Entra	SSO only: no ERIS passwords. Web OIDC code + PKCE, single tenant. The API authenticates with a **certificate** (no client secret). ERIS roles are local; users link by tenant + object ID.	Tenant/cloud, Web app, certificate issuer and rotation, first admin object ID. MFA via Conditional Access; Assignment required.
Mobile	Native Swift iOS app (in development): MSAL via Microsoft Authenticator, public client, no secret. Server exchange to a revocable ERIS session is built.	Register ERIS Mobile (iOS, bundle ID), SSO plug-in allow-list, distribution channel.
Sessions	Server-side sessions in an HttpOnly, Secure, SameSite=Strict cookie that scripts cannot read; CSRF token on writes. 30 min idle / 12 h absolute. Per-device sign-out; admin revoke ends all.	Confirm the limits. Disabling only in Entra blocks new sign-ins; offboarding also disables the ERIS account.
Files / TLS	Private S3 buckets; 15-minute signed URLs. Internal pod traffic is localhost HTTP/TCP.	TLS gateway, signed-URL forwarding, HSTS/CSP, rate limits/WAF, at-rest encryption and log redaction.
Supply chain	All five images: CycloneDX SBOM, fixable HIGH/CRITICAL and secret gate (Trivy) before push, cosign signature and signed SBOM attestation. Hosts enforce signatures and pinned digests.	Signing key owner, mirrored tool images, severity and exception approvals, digest approval.

Implemented and tested in code, not yet approved by Caltrans: Entra-only sign-in, HttpOnly server-side sessions (OWASP), certificate client credential, signed and SBOM-attested images behind a vulnerability gate, and checksummed backup/restore. Each still needs a staging test in Caltrans's tenant and infrastructure.

First administrator and handover

Fresh install creates schema and roles, not demo users. One initial admin is seeded once from the Entra object ID IT supplies; ERIS refuses to set any password. Create and verify at least two named Entra admins (ERIS refuses to disable the last one), delete bootstrap.env, and record a passing eris-pod.sh handover-check.

Web callback: https://<web-host>/api/auth/entra/callback. iOS redirect (MSAL): msauth.<bundle-id>://auth, on the separate ERIS Mobile public client (iOS platform).

DELIVERY / ACCEPTANCE

How the deployment would go

Step	Work and evidence
1. Decide	Agree Podman interpretation, data scope, host/storage, gateway names, Entra policy, Harbor/Jenkins gates, security review and recovery targets.
2. Stage	Caltrans provisions Linux/rootless Podman, two volumes, DNS/TLS gateway, firewall/egress, Entra test registration, Harbor/Jenkins and backup target.
3. Build	Jenkins builds API, worker and web from an immutable commit; all five images (with IT's MariaDB/SeaweedFS mirrors) pass the SBOM and vulnerability gate, then are pushed, signed and attested. IT approves the five digests.
4. Configure	IT supplies runtime secrets and the Entra client certificate through its approved channel and installs the signature policy. Set exact web, S3 and callback URLs.
5. Install	eris-pod.sh pull (signatures enforced), then up: schema, Alembic, private buckets, one Entra-linked admin, five containers. cert-check confirms the certificate.
6. Prove	verify-rehearsal.sh in production mode, then manual: Entra linked/unknown/unassigned/disabled users and MFA, mobile sign-in, upload and signed download, restart, reboot, backup/restore, rollback.
7. Handover	Two named Entra admins, passing handover-check, rotated handover secrets, monitoring/support owners. Production release: the staging-proven digests, after approval.

Who hands over what

ERIS team supplies	Caltrans IT supplies / approves
Approved source commit, Jenkinsfile, Podman scripts, env templates and operator runbook.	Linux host/service account, DNS/TLS gateway, private networking, firewall and egress.
Architecture/data/security packet, application tests, bootstrap and rollback procedures.	Harbor/Jenkins, cosign key, mirrored third-party and tool images, gate exceptions and five digests.
Application support and fixes found during staged acceptance.	Entra web and mobile registrations, client certificate, backup/restore, logging, alerts and change approval.

Never place populated env files, private keys, robot secrets or the cosign key in email, tickets, images or a repository. Releases: one command per host (eris-pod.sh release) pulls signed digests, backs up, migrates, verifies and rolls back by itself on failure. Jenkins can trigger it to staging, then production after approval, through a forced-command SSH key with no shell.

CALL SHEET / DECISION LOG

Ask these questions first

Priority	Question to Caltrans IT
1	Podman pod or Kubernetes/OpenShift Pod? Can DB and S3 be stateful containers in it?
1	What data classification and network zone apply? Clean install or approved data import?
1	Who owns host, rootless service account, CPU/RAM/disk, patching and SELinux policy?
1	What are the web and file HTTPS names, gateway placement, certificates and firewall rules?
1	Which Entra tenant/cloud, Web app owner, callback, first admin object ID, client certificate issuer and rotation?
1	Do 30-minute idle / 12-hour sessions meet policy? Who disables ERIS accounts at offboarding?
1	Who owns Harbor/Jenkins, the cosign key, gate exceptions? May Jenkins release over SSH, and who approves production?
1	What are the matched backup target, retention, RPO/RTO and restore-test owner?
1	Is one host's service interruption acceptable, or is a failover target required?
1	Is browser 3D ArcGIS or Esri offline processing in scope? Who supplies the restricted API key?
2	iOS app: compliant-device CA for ERIS, SSO allow-list, ERIS Mobile, enterprise profile renewal, APNs key, egress.
2	Who owns SIEM, WAF/security headers, incident response, accessibility/privacy review and go-live approval?

Likely questions from IT

They may ask	Your answer
Is it one image?	No. One Podman pod, five containers, two persistent volumes.
Who provides images?	Caltrans Jenkins builds our three; IT mirrors MariaDB/SeaweedFS. All five are gated, signed and pulled by digest.
SeaweedFS license?	Upstream 4.50 source is Apache-2.0; IT must review the exact image and dependencies. Enterprise is not proposed.
Is it highly available?	No. One host needs a tested matched backup and recovery plan.
Do people use passwords?	No. Entra SSO only; MFA and device rules come from Caltrans Conditional Access.
Is Entra live already?	Implemented and tested in code, not yet against Caltrans's tenant; the Proxmox rehearsal has no Entra.
Is mobile ready?	Not yet: native Swift iPhone app (MSAL, APNs push) via Intune/Company Portal. Server side is done.

Take into the meeting: this handout, the technical packet, Podman runbook, readiness audit, Jenkinsfile, env templates (unpopulated) and a specific source commit. The Jenkins job needs a Linux Podman agent, Harbor push robot, cosign key credentials and a 4 GiB Node heap. After decisions: hostnames/ports, signed digests with SBOMs, a non-secret config worksheet and staged acceptance/restore evidence.